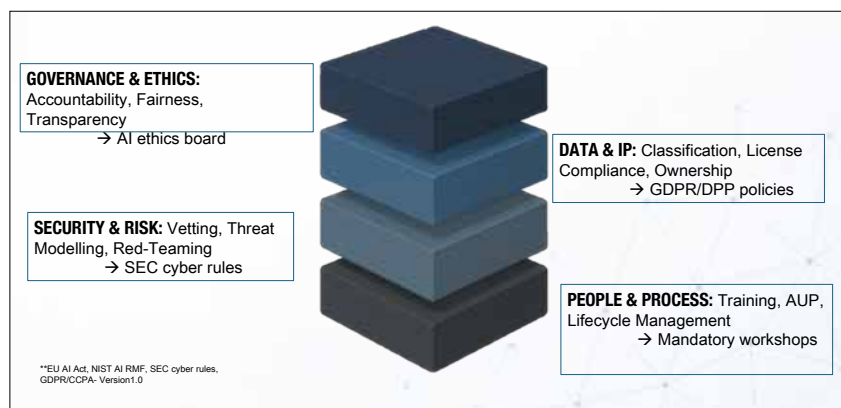




Framework for safe innovation: The AI policy stack

deployment. Separating these activities helps ensure that exploratory work does not inadvertently create compliance risks within customer-facing environments.

People and processes: Technology alone cannot solve governance challenges. Organisations must invest in education, awareness programmes, and continuous upskilling. Developers, analysts, business users, and decision-makers all need a clear understanding of both the opportunities and risks associated with AI.

The most effective governance programmes combine technical controls with organisational awareness.

Categorising AI risk

Different AI tools are exposed to different levels of risk. Hence, risk-based classifications must be used to determine the appropriate level of governance oversight provided by an AI tool.

Tools in the highest risk category (e.g., tools that process sensitive personal data and tools that must comply with a regulatory framework) generally require a formal review and approval before usage.

Tools in the second highest risk category (e.g., customer-facing tools and tools directly impacting business processes/operations with external clientele) may be allowed for usage by the MI and hence will need ongoing

compliance with regular reviews.

The last category (e.g., developers' productivity tools for use within the organisation for development, testing and infrastructure/automation management) generally has a low compliance risk as it remains within the organisation.

By classifying AI tools in this manner, an organisation can provide the greatest level of good governance.

Looking beyond surface-level compliance

A major lesson I learnt when working on AI governance is the importance of looking beyond the first layer of information available when investigating compliance issues related to AI models and software systems. For example, although a model may have an acceptable primary licence, further examination may identify one or more underlying components that have different licences (and therefore compliance requirements).

During our evaluation of Keras and YOLO-based requests, the software appeared to have an acceptable primary licence upon initial review; however, as we conducted more thorough evaluations, we identified several dependencies associated with licences that raised significant compliance issues. This was not an issue with the top-level

licences visible at the time of review, but instead with the underlying components of software systems and their associated licences, which have a substantial impact on how a model can be utilised in an enterprise.

This experience reinforced the fundamental principle that compliance reviews need to include an evaluation of the entire dependency chain rather than only the top-level licence information for any given software system.

Balancing innovation and responsibility

Open source AI represents one of the most significant technological opportunities of our time. It enables faster development, broader access to advanced capabilities, and unprecedented levels of innovation.

At the same time, organisations cannot afford to treat governance as an afterthought. Understanding model origins, reviewing licensing obligations, maintaining secure environments, protecting sensitive data, and documenting AI usage practices are all essential components of responsible adoption.

Innovation should never become a liability.

The organisations that succeed in the AI era will be those that create clear governance structures, educate their teams, and establish processes that encourage experimentation while protecting critical assets. By balancing innovation with accountability, it becomes possible to unlock the full potential of open source AI while maintaining the trust, security, and compliance that modern organisations require. **END** 🐧

The article is based on the talk at Open Source India 2025 titled 'Harnessing Open Source AI While Balancing Organisation Policies', given by Komal Pandita, senior developer, SAP Labs Pvt Ltd. It has been transcribed and curated by Nikita Kumari, journalist at the EFY Group.